

One Receipt

An end-to-end protocol that lets anyone verify one generative-AI transaction — across every interface, for every party.

Two paths, one receipt — and now the receipt has to work for the buyer, the user, the regulator and the stranger, not only for us.

Bob Rapp · Ken Johnston · with Claude

Status: for review — Ken and Bob, then the Review Circle

A profile on the standards that exist, contributed upstream; never issued by the Foundation

Source of truth: github.com/aigovops-foundation/practice · [docs/reference/ONE-RECEIPT.md](#)

Every date verified 13 September 2026. Items marked "unverified" must not be printed publicly.

Appendices A and B carry the per-claim sources.

A proposal for an end-to-end protocol that lets anyone verify one generative-AI transaction — across every interface, for every party.

Whitepaper review draft v0.1 · AiGovOps Foundation · 13 September 2026 · Authors: Bob Rapp, Ken Johnston, with Claude · Status: **for review** (Ken and Bob; then the Review Circle). Review page: the artifact "One Receipt" (kept current; never re-created).

Assumption stated up front: "UP Path" in the brief is read as UiPath — founding contributor to, and first platform certified under, AIUC-1. Every claim below carries a source (research memos in *research/*); items marked "unverified" could not be confirmed on 13 September 2026 and must not be printed publicly.

0. In one paragraph

Today a person can talk to an AI in a chat window, through an API, by voice, inside an IDE, through a browser extension, on a phone, or through another agent — and no party can later prove, without trusting the operator, what model answered, under which policy, on whose authority, with what checks, and whether the record was altered afterwards. Eleven standards bodies each hold one piece: ISO 42001 certifies the organisation, AIUC-1 certifies the agent quarterly, OVERT signs the decision, C2PA signs the file, SCITT gives the transparency log, AP2 signs the shopping mandate, OpenTelemetry names the fields, the EU AI Act says logs must exist. Nothing joins them into **one receipt per transaction that a stranger can verify offline**. This paper proposes that receipt — content-free, signed, chained, interface-agnostic — as a *profile that sits on the standards that exist*, contributed upstream rather than issued by the Foundation, and governed so that no party that sells the runtime also grades it.

1. The eight seams

- 1. No transaction identifier.** Only China's labelling rules (in force 1 Sep 2025) require a per-output "content reference number". MCP's 2026-07-28 spec *removed* session ids; OpenTelemetry's `gen_ai.*` conventions are still "Development" and unsigned. No id survives chat → API → agent → extension → product.
- 2. Identity is split three ways and never bound.** Human (OIDC, W3C VC 2.0), workload (SPIFFE/WIMSE, `draft-klrc-aiagent-auth-03`), and agent/model (A2A signed Agent Cards; ITU FG-TIDA, first meeting Nov 2026). Nothing signs *human + agent + model version + tool* together at call time.
- 3. Policy decisions are asserted, not attested.** ISO 42001, NIST AI RMF, CSA AICM v1.1 and EU Arts 9–14 say controls must exist; only OVERT 1.1 specifies a per-action proof that a control ran — and OVERT has one vendor implementation, no registered Independent Attestation Provider, and no assessor registry yet. The EU's harmonised logging standard, prEN 18229-1, is at Enquiry stage.
- 4. Transparency logs have a transport but no AI payload.** RFC 9943 (SCITT architecture) and RFC 9942 (COSE receipts) were published June 2026; there is no registered SCITT statement profile for "AI inference / agent action". OVERT does not reference SCITT.
- 5. Provenance is bound to the asset, not the session.** C2PA 2.3 and IPTC 2025.1 describe what produced a *file*; free-form text, voice and code — most of what generative AI emits — carry nothing, and platforms strip manifests.
- 6. Audit rights stop at the organisation.** EU Art. 12/26(6) logs are for the provider, deployer and regulator; ISO 42006 accredits auditors of *management systems*; there is no "verify with a public key, offline" norm outside Sigstore and OVERT tooling.
- 7. Incidents are narrative.** Art. 73 templates, OECD AIM, AIID and the Frontier Model Forum's incident sharing accept prose; none takes a receipt hash or inclusion proof as the anchor. NYC Local Law 144's audit regime produced two complaints and no enforcement in two years — evidence that summaries without artefacts do not work.
- 8. Interfaces are uneven.** Voice has no marking channel; coding agents have AGENTS.md (guidance); on-device AI has RATS (RFC 9334) but no AI profile; A2A puts authorisation out of scope by design; commerce protocols (AP2, Visa TAP, Mastercard Verifiable Intent, OpenAI/Stripe ACP) prove *who* transacted but not *what the model did* between intent and cart.

2. What exists, in one table

LAYER	STANDARD (STEWARD, STATUS)	WHAT IT ANSWERS	WHAT IT CANNOT
Organisation	ISO/IEC 42001:2023 (+42005 impact, 42006 audit bodies); NIST AI RMF 1.0 + AI 600-1	Does the operator have a management system?	Anything about one transaction
Agent (periodic)	AIUC-1 (AIUC; quarterly releases, Jul 2026 current; six domains; third-party audit + quarterly adversarial testing; insurance-priced; UiPath, Intercom, Cursor, Harvey, ElevenLabs, KPMG certified)	Was this agent tested and insured this quarter?	Whether the certified controls ran on <i>your</i> call
Decision (runtime)	OVERT 1.1 (Glacis, 11 Jun 2026; six domains; AAL-1...4; IAP + Qualified Assessor defined, none registered)	Did a control execute on this action, signed and chained?	Cross-vendor adoption; SCITT/C2PA/OTel mapping; human mandate
Log	IETF SCITT RFC 9943 / RFC 9942 (Jun 2026); Sigstore Rekor v2 (Oct 2025)	Was the statement registered and unaltered?	What an AI statement should contain

LAYER	STANDARD (STEWARD, STATUS)	WHAT IT ANSWERS	WHAT IT CANNOT
Identity	W3C VC 2.0 / DID 1.1 CR; SPIFFE; <code>draft-klrc-aiagent-auth</code> ; OpenID AIIM CG; Cloudflare Web Bot Auth (operator only, forbids human binding)	Who is the human / workload / bot?	Binding all three to one act
Mandate	Google AP2 (Sep 2025; Intent/Cart/Payment Mandates as VCs); Mastercard Verifiable Intent (Mar 2026); Visa TAP (RFC 9421 signatures); OpenAI/Stripe ACP (allowance tokens)	What did the human authorise the agent to buy?	Anything outside commerce; what the model did
Telemetry	OpenTelemetry GenAI semconv v1.42 (Development)	Field names for model, tokens, tools, agents	Signing; stability
Content	C2PA 2.3 (Feb 2026); IPTC 2025.1; EU Transparency Code (Jun 2026) + Art. 50 Guidelines (Jul 2026)	What produced this file?	Text/voice/code; the session
Supply chain	CycloneDX 1.7 ML-BOM; SPDX 3.0.1 AI profile; OpenSSF Model Signing 1.0	What is the model made of?	The transaction
Regulation	EU AI Act as amended by (EU) 2026/1744: Art. 12 logging, Art. 50 (live 2 Aug 2026), Annex III 2 Dec 2027, Art. 73 incidents; Colorado SB 26-189 (1 Jan 2027); Korea AI Basic Act (22 Jan 2026); China labelling (1 Sep 2025); California SB 942 (2 Aug 2026)	What must be logged, disclosed, explained, reported	A format; a verifier
Incidents	OECD AIM; AIID; AIAAIC; FMF incident sharing (May 2026); MIT tracker	What went wrong, in prose	Linkage to evidence
Confidential compute	Apple PCC (expanded to Google Cloud, Jun 2026); Google Confidential Space; Intel Trust Authority	Which binary ran, in which enclave	What it answered

3. The proposal

3.1 One receipt, six stages

A **receipt** is a content-free, signed statement about one *transaction* — one request and its response, or one agent action — chained into a transparency log, with pointers (never payloads) to the evidence each stakeholder may later be entitled to see.

STAGE	FIELD GROUP	BINDS	BUILT ON
1 Identity	<code>principal</code> (human subject or "none"), <code>operator</code> , <code>agent</code> , <code>model</code> (name, version, weights hash or BOM ref)	Who acted, on whose behalf, with what	OIDC/VC 2.0 subject; Web Bot Auth key; A2A Agent Card; SPDX/CycloneDX ref
2 Mandate	<code>mandate</code> (hash of a signed intent, scope, limits, expiry)	What the human authorised	AP2 Intent/Cart Mandate VC; Mastercard Verifiable Intent; or a Foundation "plain-words rule" for non-commerce
3 Policy	<code>policy</code> (policy id + version hash, tier, decision $\in$ {allow, constrain, hold, deny}), <code>controls[]</code> (executed with outcomes, human-in-loop flag)	Which gate ran and what it decided	OVERT GOVERN/PROTECT ControlActions; AIUC-1 control ids; CSA AICM ids; Umbrella UCID
4 Runtime	<code>io</code> (salted commitments to input and output, token counts, latency), <code>env</code> (TEE attestation ref if any), <code>tools[]</code> (each tool call as a nested receipt id)	What was computed, where	OTel GenAI attributes; RATS RFC 9334 evidence; MCP/A2A ids
5 Provenance	<code>output_manifest</code> (C2PA manifest hash or "text: none"), <code>disclosure</code> (was the AI nature disclosed; how)	What left the system and how it was marked	C2PA 2.3; Art. 50; China reference number
6 Audit	<code>log</code> (SCITT transparency-service id, inclusion proof, checkpoint), <code>registry</code> (Art. 71 / ATRS / AIUC-1 cert / OVERT profile ids), <code>explain_ref</code> , <code>complaint_ref</code> , <code>retention</code>	Where the proof lives; how to challenge it	RFC 9943/9942; Art. 86; Art. 26(6) six-month floor

Envelope: COSE_Sign1 over a CBOR/JCS-canonical body, Ed25519 by default with a hybrid post-quantum option; registered as a **SCITT statement profile** so any RFC 9943 transparency service can hold it. Selective disclosure via SD-JWT (RFC 9901) for the pointer fields. One receipt id, one URL pattern (`.../r/<id>`), one offline verifier.

3.2 Interface profiles

The same six stages; what changes is how the id is carried and how the user sees it.

INTERFACE	ID CARRIER	DISCLOSURE TO THE USER	NOTES
Chat / web	Response header + a visible "receipt" affordance	Link under every answer	The café's Wren Card pattern
API	<code>AI-Receipt</code> response header (id + log URL); request may carry <code>AI-Mandate</code>	Client's responsibility; SDK prints it	Maps 1:1 to OTel span
Voice	Spoken id on request; DTMF/URL in transcript	"Say 'receipt'"	Fills the only channel Art. 50 admits is weak
Agent-to-agent	A2A message metadata; nested receipts per hop	Root receipt for the human principal	MCP has no session id — the receipt is the session

INTERFACE	ID CARRIER	DISCLOSURE TO THE USER	NOTES
Browser extension / IDE	Receipt id in the edit/commit trailer	Receipt: git trailer	Coding agents already sign commits
Embedded product / phone	On-device receipt with TEE evidence; uploads when online	Settings → receipts	RATS profile
Commerce	AP2 Cart Mandate hash in mandate	Merchant receipt cites it	Visa/Mastercard/ACP compatible

3.3 Roles — and the independence rule

- **Operator** (seller/deployer) issues receipts.
- **Notary** (transparency service) registers them — structurally outside the operator's trust boundary above assurance level 2.
- **Assessor** verifies samples without content access — never the same legal entity as the notary or the operator, and never the party that sells the runtime.
- **Registry** holds the public entries a receipt points to (EU Art. 71 database when live; UK ATRS; AIUC-1 certificate ids; OVERT profile ids).
- **Verifier** is anyone with the public key and the log — no account, no network required.

Assurance ties directly to OVERT's AAL-1...4 so nothing is re-invented: level 1 self-declared, 2 operator records, 3 operator-hosted notary, 4 independent notary + assessor. The addition is a **certificate-to-receipt link**: a quarterly certificate (AIUC-1, ISO 42001) becomes checkable against per-call evidence — "you said control A006 exists; show me it ran on the calls that mattered".

3.4 What each party can now ask, and get

PARTY	QUESTION	ANSWERED BY
Buyer / deployer	Which model and system-prompt hash served this call? Did the certified control run? Can I keep six months of evidence without holding content?	stages 1, 3, 4, 6
End user	Was I talking to an AI, run by whom? What did I authorise, and did the agent stay inside it? Where is the explanation this exact interaction owes me (Art. 86, SB 26-189)? Can I prove my session was deleted?	stages 1, 2, 5, 6 (explain_ref , retention)
Regulator	Is the vendor's marketing claim traceable to production runs (FTC substantiation)? Was the log altered after the incident? Can I inspect without trade secrets (Art. 78)?	stages 3, 4, 6; SD-JWT disclosure
Civil society	Is this system in a public register, and does the receipt say so? Can an independent auditor verify a sample without the vendor's cooperation? Is there a complaint channel keyed to the receipt id?	stage 6 (registry , complaint_ref); assessor role
Seller / vendor	Can I prove controls ran without exposing prompts or weights? Does the receipt lower my premium and liability? Is human intent separated from my agent's identity so I am not liable for what I never authorised?	content-free by design; mandate separates the human from the agent; insurers (AIUC, Armilla/Lloyd's, Munich Re) already price on audits — receipts are the next step

4. What it improves on

The AiGovOps Foundation. Beacon already signs Ed25519 over JCS with an append-only Merkle log and an offline **VERIFY.md**; Umbrella already compiles law to UCIDs and binds receipts to controls; Lantern already reads them. What the Foundation lacks is the *shape*: its receipt is its own, not a SCITT statement; it has no **principal/mandate**, no interface profiles, no certificate link, and no registry pointers. Adopting One Receipt means Beacon emits a SCITT-profiled envelope, Lantern's verify page becomes the reference verifier, the 100-case corpus becomes the test-vector set (each case's plain-words gate as the **policy** fixture), and the practitioner ladder maps rung-for-rung: a 100 reads a receipt, a 200 emits one from CI, a 300 runs a notary with holds, a 400 verifies a stranger's receipt offline. The Foundation's own rule stands: it issues no standard; it contributes this upstream and implements it first.

Glacis / OVERT. OVERT is the best-specified per-decision receipt in the field and this proposal keeps its domains and AALs intact. It improves on it in four ways OVERT's own crosswalks leave open: (1) a SCITT profile so any transparency service can hold OVERT receipts, not only Glacis's notary; (2) OTEL, C2PA and AP2 mappings; (3) explicit human-mandate and disclosure fields (OVERT scopes out truthfulness and user-facing obligations); (4) a governance separation — today the OVERT steward sells the runtime and would qualify the assessors, and no assessor or IAP is registered fourteen months after 1.0. The ask to Glacis is unchanged from May: sign the Beacon profile; co-author the SCITT profile; let the community's 400s form the first verification pool.

AIUC-1 and the insurance track. AIUC-1 is the strongest *periodic* certification — audited, adversarially re-tested quarterly, priced into cover — and its 120-member consortium (UiPath among the founding contributors) is the widest industry table. Its limits are structural: a certificate says the agent passed last quarter, not that control A006 ran on this call; the standard's editor also accredits auditors and underwrites the policy. One Receipt gives AIUC-1 what it cannot produce itself — per-call evidence that a certified control executed — and gives insurers a loss-adjustment artefact. The ask: an AIUC-1 requirement that certified agents emit receipts, and a control-id vocabulary shared with OVERT.

5. Standards path and governance

1. **IETF SCITT** — an Internet-Draft "AI Transaction Statement Profile" (the six stages as a CBOR map; RFC 9942 receipts). Co-authors sought from Glacis, Microsoft (SCITT editors), and one payments network.
2. **OVERT** — a registered profile `one-receipt.v1` under Agentic-Extended scope; Beacon's `aigovops-beacon.v1` conforms to it.
3. **OpenTelemetry** — a mapping table `gen_ai.*` ↔ receipt fields, submitted to the semantic-conventions-genai repo.
4. **C2PA** — an assertion type carrying the receipt id, so a signed file points back to the session.
5. **AP2 / Mastercard Verifiable Intent** — the `mandate` slot accepts their credentials unchanged.
6. **NIST AI Agent Standards Initiative / NCCoE** — the interface-profile matrix as a public-interest use-case submission; **ITU FG-TIDA** (Nov 2026) for the identity binding.
7. **EU** — feed the six-month retention and content-free pattern into the prEN 18229-1 (Art. 12 logging) enquiry; propose the receipt id as the Art. 73 incident anchor.

Governance: a multi-stakeholder working group with a seat each for sellers, buyers, users, regulators (observer) and civil society; a rule that no member sells the notary or assessor service for a system it operates; royalty-free IPR (the OVERT covenant pattern); test vectors and reference verifier in the open.

6. Ninety days for the Foundation

- **Weeks 1–3:** the SCITT profile draft and test vectors from ten corpus cases; Beacon emits `one-receipt.v1` behind a flag.
- **Weeks 4–6:** Lantern verify page reads it; the café's Wren Card shows a receipt id; interface profiles for chat, API and IDE shipped in the 200 worksheet.
- **Weeks 7–9:** the Glacis ask; the AIUC-1 contribution; the NIST submission; a Thursday devoted to a stranger verifying a receipt offline.
- **Weeks 10–13:** first external verification by a 400; the joint story; v0.2 of this paper with what broke.

7. Risks and open questions

Salted commitments are the privacy floor, but a hash cannot explain — `explain_ref` must be honoured or Art. 86 is unmet. Receipts for every token of a streaming voice session need a batching rule. On-device and TEE evidence is environment-level, not answer-level; the paper does not claim otherwise. zkML proof-of-inference (Lagrange DeepProve, EZKL) is not viable per request at frontier scale in 2026. Adoption will follow procurement clauses and insurance premiums, not goodwill — the EU model contractual clauses (MCC-AI, Mar 2025) and AIUC pricing are the levers. And the Foundation must not become the thing it warns against: it implements and teaches; it does not grade its own receipts.

8. Decisions for Ken and Bob

1. Name: **One Receipt** (working) — yes/no.
2. Send the Glacis ask now with §4 attached, or after the SCITT draft exists.
3. Whether the Foundation proposes the working group or asks the Agentic AI Foundation (Linux Foundation) to host it.
4. Which ten corpus cases become the first test vectors.

9. Sources

Full, dated, per-claim sources are in `research/2026-09-13-standards-landscape.md` and `research/2026-09-13-transactions-and-stakeholders.md`. Selected: OVERT 1.1 standard, conformance and crosswalks (overt.is); Glacis docs and verifier (docs.glacis.io, verify.glacis.io); GeekWire on Glacis (7 Apr 2026); AIUC-1 site and changelog (aiuc-1.com); UiPath AIUC-1 announcements (19 Nov 2025; 9 Mar 2026); RFC 9943, RFC 9942, RFC 9901, RFC 9421; draft-klrc-aiagent-auth-03; draft-meunier-web-bot-auth-architecture-05; Regulation (EU) 2026/1744 and law-firm summaries (White & Case, Orrick, Gibson Dunn); AI Act Explorer Arts 12, 14, 50, 71, 73, 78, 86; Commission Transparency Code (10 Jun 2026) and Guidelines (20 Jul 2026); KLA JTC 21 tracker (prEN 18229-1); C2PA 2.3 spec; IPTC 2025.1; Google AP2 announcement; Visa Trusted Agent Protocol; Mastercard Verifiable Intent (PYMNTS, 5 Mar 2026); OpenAI ACP delegated payment spec; Cloudflare Web Bot Auth; Linux Foundation AAI and A2A releases; MCP spec 2026-07-28; OpenTelemetry semconv 1.41/1.42; CSA AICM v1.1; MITRE ATLAS v2026.08; OWASP Agentic Top 10 (2026); NIST AI Agent Standards Initiative; NCCoE agent identity concept paper; ITU FG-TIDA; NY State Comptroller audit of Local Law 144 (2 Dec 2025); Colorado SB 26-189; Korea AI Basic Act (Cooley); China labelling measures (China Law Translate); Ada Lovelace *Code & Conduct*; Apple PCC expansion (8 Jun 2026); Lagrange DeepProve-1; Attested Intelligence AGA.

How to read this. Every date was checked on 13 September 2026 and lives in the two research memos that follow as appendices. Anything marked **unverified** is a claim we could not confirm. Section 8 is the part that needs a yes.

Research memo 1 — the global AI-governance standards landscape (13 September 2026)

Briefing for the One Receipt whitepaper. Every dated claim carries a source. Items that could not be confirmed are marked "unverified".
Researched with web search on 13 September 2026 by Claude for Bob Rapp.

1. Management & risk standards

STANDARD	STEWARD	CURRENT VERSION / STATUS (VERIFIED)	WHAT IT STANDARDISES	NOT COVERED	RECEIPT-PROTOCOL HOOK
ISO/IEC 42001	ISO/IEC JTC 1/SC 42	42001:2023 published; still edition 1 (https://www.iso.org/standard/42001). A CEN "EN ISO/IEC 42001:2026" listing exists (https://standards.iteh.ai/catalog/standards/cen/adc675e8-4669-4965-b4c1-c8f724832217/en-iso-iec-42001-2026) — European adoption, content unverified	AI management system (AIMS): policy, roles, risk, impact assessment, lifecycle controls (Annex A)	Runtime evidence; per-transaction logging format; cross-org verification	Receipts are the evidence an AIMS auditor asks for under A.6/A.8 controls
ISO/IEC 42005:2025	SC 42	Published 2025 (https://www.iso.org/standard/42005)	AI system impact assessment process	Nothing machine-readable; no runtime	Impact-assessment id referenced in the receipt
ISO/IEC 42006:2025	SC 42 / CASCO	Published July 2025, ed. 1 (https://www.iso.org/standard/42006)	Requirements for bodies auditing/certifying AIMS (supplements 17021-1)	Product/system certification	Defines the accredited third parties who could act as receipt auditors
ISO/IEC 23894, 5338	SC 42	23894:2023 (risk guidance) and 5338:2023 (AI lifecycle) per https://www.iso.org/sector/s/it-technologies/ai ; no 2026 revisions found	Risk guidance (ISO 31000 lens); lifecycle process model	Formats, receipts	Lifecycle stage vocabulary for a receipt "phase" field
NIST AI RMF 1.0 + AI 600-1	NIST	RMF 1.0 (Jan 2023) and GenAI Profile AI 600-1 (July 2024) remain current; no "RMF 2.0" (https://www.ispartnersllc.com/blog/nist-ai-rmf-2025-2026-updates-what-you-need-to-know-about-the-latest-framework-changes/)	Govern/Map/Measure/Manage; GenAI risk list and actions	Not auditable; no evidence format	MEASURE/MANAGE map to attest/incident stages
NIST Cyber AI Profile + COSAIs	NIST	Preliminary draft CSF 2.0 AI Profile 16 Dec 2025, comments to 30 Jan 2026; SP 800-53 "Control Overlays for Securing AI Systems" in development (https://www.globalpolicywatch.com/2026/01/nist-publishes-preliminary-draft-of-cybersecurity-framework-profile-for-artificial-intelligence-for-public-comment/ ; https://csrc.nist.gov/Projects/cosais/publications)	Secure/Defend/Thwart focus areas over CSF functions	Draft	Control ids for a receipt "controls evaluated" field
NIST AI Agent Standards Initiative	NIST / CAISI	Launched 17 Feb 2026; CAISI RFI on agent security closed 9 Mar 2026; three workstreams (https://www.nist.gov/artificial-intelligence/ai-agent-standards-initiative)	Convening, gap analysis	No spec yet	Likely venue for a receipt profile
NCCoE Software & AI Agent Identity and Authorization	NIST NCCoE	Concept paper Feb 2026; comments closed 2 Apr 2026; "reviewing comments", no build started (https://www.nccoe.nist.gov/projects/software-and-ai-agent-identity-and-authorization)	Applying identity standards to enterprise agents	Not a standard	Identity-stage reference implementation
CSA AI Controls Matrix	Cloud Security Alliance	AICM v1.1, 26 June 2026: 247 controls, 18 domains (new Model Security domain), AI-CAIQ v1.1 (320 questions), mappings to ISO 42001, NIST AI RMF/600-1, EU AI Act, AIUC-1 (https://virtualizationreview.com/articles/2026/06/26/cloud-security-ai-controls-matrix-turns-ai-governance-into-assessment-framework.aspx)	Shared-responsibility control set	Runtime evidence	Control ids as receipt vocabulary
MITRE ATLAS	MITRE	v2026.08 (1 Sep 2026): 16 tactics, 114 techniques, 83 sub-techniques, 39 mitigations, 72 case studies; 18 new autonomous-agent techniques (https://github.com/mitre-atlas/atlas-data/releases)	Adversary TTP taxonomy	Controls/evidence	ATLAS technique ids in incident records

STANDARD	STEWARD	CURRENT VERSION / STATUS (VERIFIED)	WHAT IT STANDARDISES	NOT COVERED	RECEIPT-PROTOCOL HOOK
OWASP GenAI Security Project	OWASP	Top 10 for Agentic Applications 2026 (9 Dec 2025); GenAI LLM Top 10 2026 (3 Aug 2026) (https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-f-or-2026/ ; https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/)	Risk lists	No format	Risk tags for the policy stage

2. Regulation

EU AI Act (Reg. 2024/1689) as amended by the Digital Omnibus on AI, Regulation (EU) 2026/1744, OJ 24 July 2026, in force 27 July 2026 (<http://www.whitecase.com/insight-alert/eu-ai-omnibus-enters-force-amending-ai-act>); political agreement 6 May, Council 13 May 2026 (<https://www.gibsondunn.com/eu-ai-act-omnibus-agreement-postponed-high-risk-deadlines-and-other-key-changes/>); Council final green light 29 Jun 2026 (<https://www.consilium.europa.eu/en/press/press-releases/2026/06/29/artificial-intelligence-council-gives-final-green-light-to-simplify-and-streamline-rules/>); Orrick's eight changes (<https://www.orrick.com/en/Insights/2026/07/EU-AI-Act-Update-Digital-Omnibus-Finalizes-8-Compliance-Changes>).

OBLIGATION	DATE
Annex III stand-alone high-risk (Arts 9–15, 17, 72, 73)	2 Dec 2027 (was 2 Aug 2026)
Annex I embedded high-risk	2 Aug 2028
Art. 50 transparency (chatbot disclosure, deepfake labels)	2 Aug 2026, unchanged
Art. 50(2) machine-readable marking for systems on the market before 2 Aug 2026	grace to 2 Dec 2026
New Art. 5 prohibitions (NCII/CSAM generators)	2 Dec 2026
GPAI obligations / AI Office enforcement	in force 2 Aug 2025; enforcement from 2 Aug 2026; legacy models by 2 Aug 2027 (https://artificialintelligenceact.eu/code-of-practice-overview/)

- Art. 12 record-keeping: automatic event logging over the lifetime; for Annex III 1(a) biometrics the minimum log is period of use, reference database, matching input data, identity of verifying persons (<https://artificialintelligenceact.eu/article/12/>). Harmonised standard prEN 18229-1 (Logging) at Enquiry; EN 18286 (QMS) at Formal Vote; JTC 21 targeted Q4 2026; M/613 deadline 28 Feb 2027 (<https://kla.digital/blog/jtc-21-standards-tracker>).
- Art. 13/14 (transparency to deployers; human oversight): prEN 18229-2/-3 drafting (<https://artificialintelligenceact.eu/article/14/>).
- Art. 50: Commission Guidelines 20 July 2026; Code of Practice on Transparency of AI-generated Content finalised 10 June 2026, ~190 signatories; the "standard solution" is signed metadata plus imperceptible watermarking; agents must disclose artificial nature and on whose behalf they act (<https://www.faedredrinker.com/en/insights/publications/2026/7/eu-ai-act-commission-confirms-transparency-code-of-practice-as-adequate-and-publishes-final-version-of-its-guidelines-on-transparency-obligations>; <https://digital-strategy.ec.europa.eu/en/policies/code-practice-ai-generated-content>).
- Art. 72/73: 15/10/2-day deadlines (<https://artificialintelligenceact.eu/article/73/>); draft guidance + template consulted to 7 Nov 2025; final high-risk guidance unverified; GPAI systemic-risk incident template 4 Nov 2025 (<https://digital-strategy.ec.europa.eu/en/library/ai-act-commission-publishes-reporting-template-serious-incidents-involving-general-purpose-ai>).
- GPAI Code of Practice: 10 July 2025, three chapters (<https://artificialintelligenceact.eu/code-of-practice-overview/>).

United States. Colorado: federal order 27 Apr 2026 blocked SB 24-205; SB 26-189 signed 14 May 2026, notice-based regime effective 1 Jan 2027 (<https://www.mcdermottlaw.com/insights/colorado-ai-law-in-flux-comprehensive-replacement-bill-signed-after-federal-court-blocks-predecessors-enforcement/>). California: SB 53 and AB 2013 effective 1 Jan 2026; SB 942 AI Transparency Act effective 2 Aug 2026 after AB 853; CPPA ADMT rules 1 Jan 2026 / 1 Jan 2027 (<https://secureprivacy.ai/blog/california-ai-transparency-law>). Federal: CISA/NSA/Five Eyes agentic-AI guidance 1 May 2026; CAISI pre-deployment agreements 5 May 2026 (<https://labs.cloudsecurityalliance.org/research/csa-research-note-agentic-ai-governance-cisa-nist-caisi-2026/>).

United Kingdom. No AI Act; King's Speech 13 May 2026 (Regulating for Growth Bill; Police Reform Bill); Crime and Policing Act 2026; ICO AI-cyber guidance May 2026; autumn 2026 taskforce report on labelling promised (<https://www.osborneclarke.com/insights/regulatory-outlook-may-2026-artificial-intelligence>; <https://www.twobirds.com/en/insights/2026/ai-in-the-kings-speech-2026-regulating-for-growth-bill-announced>); DSIT Trusted Third-Party AI Assurance Roadmap (Sept 2025) (<https://www.burges-salmon.com/articles/10215fo/trusted-third-party-ai-assurance-dsit-roadmap/>).

Singapore. IMDA Model AI Governance Framework for Agentic AI (Jan 2026, updated May 2026); AI TAP planned Q3 2026; ISO/IEC 42119-8 proposed Apr 2026; MAS MindForge Mar 2026 (<https://www.mayerbrown.com/en/insights/publications/2026/07/ai-regulation-in-singapore-and-hong-kong-a-mid-year-checkpoint>); Project Moonshot / AI Verify continue (<https://www.imda.gov.sg/resources/blog/blog-articles/2026/02/redefining-g-ai-safety>).

Japan. AI Promotion Act in force 4 June 2025; AI Basic Plan 14 July 2026; Guidelines for Business v1.2 (31 Mar 2026); AISI Evaluation Guide v1.20 (7 Jul 2026) (<https://vorlabs.com/ai-regulatory-updates/japan/2026-07/ai-promotion-act-basic-plan-business-guidance>).

Korea. AI Basic Act effective 22 Jan 2026: high-impact duties, generative notice and labelling, fines $\leq$ KRW 30M, ≥ 1 -year grace (<https://www.cooley.com/news/insight/2026/2026-01-27-south-koreas-ai-basic-act-overview-and-key-takeaways>).

China. Labeling Measures effective 1 Sep 2025: explicit labels plus implicit metadata (content attribute, provider name/code, content reference number); GB 45438-2025 (<https://www.chinalawtranslate.com/en/ai-labeling/>; <https://www.loeb.com/en/insights/publications/2025/03/chinas-ai-labeling-measures-and-mandatory-national-standards-take-effect-september-1>). The only regime mandating a per-output reference number.

3. Provenance & content

ITEM	STATUS	GAP FOR SESSION RECEIPTS
C2PA Content Credentials 2.3 (spec 5 Jan 2026; launch 9 Feb 2026): live video, plain text, richer edit actions; Conformance Program; ">6,000 members and affiliates" (https://c2pa.org/the-c2pa-launches-content-credentials-2-3-and-celebrates-5-years-of-impact-across-the-digital-ecosystem/; https://spec.c2pa.org/specifications/specifications/2.3/specs/_attachments/C2PA_Specification.pdf)	Published, adopted	Binds assertions to an asset, not the session/API call; no human principal; stripped by platforms (https://arxiv.org/html/2604.24890v1)
IPTC Photo Metadata 2025.1 (27 Nov 2025): AI System Used/Version, AI Prompt Information, AI Prompt Writer Name; adding IPTC fields can invalidate C2PA manifests (https://iptc.org/news/iptc-photo-metadata-standard-2025-1-adds-ai-properties/)	Published	Images only; no signature
W3C PROV-O (Rec. 2013) (https://www.w3.org/TR/prov-o/)	Stable	Good vocabulary; no signing/transport
SynthID (Google) text watermark open-sourced; detector portal (https://synthid-detector.com/)	Proprietary per vendor	Detects; does not attest who/why
EU Transparency Code (10 Jun 2026) + Art. 50 Guidelines (20 Jul 2026)	Published, voluntary/safe harbour	Requires marking, not verifiable session linkage
D&TA Data Provenance Standards v1.0.0 (9 Jul 2024) → OASIS DPS TC (https://www.dtaalliance.org/news/announcing-the-data-provenance-standards-v1-0-0; https://www.oasis-open.org/tc-dps/)	Committee	Training data, not runtime

4. Identity & authorization

- W3C VC 2.0 Recommendation 15 May 2025 (<https://www.w3.org/press-releases/2025/verifiable-credentials-2-0/>); VC WG charter Mar 2026–Mar 2028 (VCDM 2.1 expected Apr 2027) (<https://w3c.github.io/vc-charter-2026/>); DID 1.1 Candidate Recommendation 5 Mar 2026 (<https://w3.org/news/2026/w3c-invites-implementations-of-decentralized-identifiers-dids-v1-1/>). Nothing agent-specific.
- IETF: draft-klrc-aiagent-auth-03 (6 Jul 2026; Kasselmann, Lombardo, Rosomakho, Campbell, Steele, Parecki) composing WIMSE, SPIFFE, OAuth 2.0, Transaction Tokens, CIBA, HTTP Message Signatures, Shared Signals (<https://datatracker.ietf.org/doc/draft-klrc-aiagent-auth/>); draft-oauth-transaction-tokens-for-agents-04; draft-ni-wimse-ai-agent-identity-02. WG adoption status unverified.
- OpenID Foundation AIIM CG (chartered Apr 2025): whitepaper Oct 2025; flags the gap "how to assert the identity of the LLM and/or agent to external servers" (<https://openid.net/cg/artificial-intelligence-identity-management-community-group/>).
- ITU-T FG-TIDA (Trust and Identity for Humans and Agentic AI), under SG17, announced 9 Jul 2026; first meeting Paris Nov 2026, second Geneva Jan 2027 (<https://www.itu.int/en/mediacentre/Pages/PR-2026-07-09-focus-group-agentic-AI.aspx>).
- CoSAI (OASIS): MCP Security Taxonomy (27 Jan 2026); agentic identity research and Open Delegation & Identity Standard (ODIS) workstream (6 May 2026) (<https://www.coalitionforsecureai.org/coalition-for-secure-ai-unveils-new-agentic-identity-and-security-research-following-high-profile-sessions-at-rsac-2026/>).
- Vendors: Auth0/Okta agent identity (<https://www.okta.com/newsroom/press-releases/auth0-platform-innovation/>); Workday "Agent Passport" (2 Jun 2026) — a product, not a standard (<https://newsroom.workday.com/2026-06-02-Workday-Launches-Agent-Passport-to-Test-Verify-and-Continuously-Monitor-Every-AI-Agent-in-the-Enterprise>). SPIFFE/SPIRE has no agent-specific spec.

5. Transparency logs & attestations

- RFC 9943 SCITT Architecture — Proposed Standard, June 2026: Transparency Service, Signed Statements (COSE_Sign1), Registration Policy, Receipts (<https://www.rfc-editor.org/rfc/rfc9943.html>). RFC 9942 COSE Receipts — June 2026 (<https://www.rfc-editor.org/rfc/rfc9942.html>). SCRAPI draft-ietf-scitt-scrapi-11 in the RFC Editor queue (<https://datatracker.ietf.org/doc/draft-ietf-scitt-scrapi/>). RFC 9162 CT v2 lineage.
- Sigstore Rekor v2 GA 10 Oct 2025 (<https://blog.sigstore.dev/rekor-v2-ga/>); OpenSSF Model Signing v1.0 (Apr 2025); SLSA v1.2 (24 Nov 2025), no AI track (<https://slsa.dev/blog>).
- OVERT 1.1 (Glacis): v1.1 published 11 June 2026, identifier overt.is/1.1, royalty-free patent covenant (<https://overt.is/>; <https://overt.is/ipr-policy>). Six domains GOVERN, IDENTIFY, PROTECT, ATTEST, MEASURE, RESPOND; AAL-1 self-asserted docs → AAL-2 operator records → AAL-3 machine telemetry → AAL-4 independently signed proofs, zero content access; IAP structurally independent, 72-hour incident disclosure (https://overt.is/OVERT_v1.1_STANDARD.pdf). Conformance: four maturity levels (Foundation, Enforcement, Measurement, Evidence-Grade), scope Core / Agentic / Agentic-Extended, SD- self-declared profiles valid only to Level 2, Qualified OVERT Assessor mandatory at Level 4, assessor registry maintained by Glacis; no IAPs or assessors named (https://www.overt.is/OVERT_1.1_Conformanc

e.pdf). Crosswalks: NIST AI RMF/600-1, ISO 42001, EU AI Act, AIUC-1, OWASP Agentic, SP 800-53/FedRAMP, OMB M-25-21/22, DAS F 3.0, IMDRF N93, CHAI; MCP-1..3; no SCITT, C2PA or OpenTelemetry mapping (https://www.overt.is/OVERT_1.1_Crosswalks.pdf). Normative refs include RFC 9334 RATS and RFC 6962. Out of scope: training, data lifecycle, output truthfulness, infra security, legal guarantees.

- Glacis (GeekWire 7 Apr 2026): Joe Braidwood CEO, Dr Jennifer Shannon CMO, Rohit Tatachar co-founder/CTO from Microsoft Foundry; \$575k raised; 5 staff; Arbiter, Witness Network, auto-redteam; two healthcare pilots (<https://www.geekwire.com/2026/seattle-startup-glacis-b-rings-longtime-microsoft-leader-aboard-to-target-ais-biggest-blind-spot/>). Docs: receipts signed and chained, hashes/line-ranges not content, offline-verifiable; runtime "OVERT Level 1 Core / AAL-3" (<https://docs.glacis.io/>). Independent adoption of OVERT beyond Glacis: none found.

6. Telemetry & interoperability

- OpenTelemetry GenAI semconv still "Development": v1.41.0 (28 Apr 2026) streaming metrics/agent operation types; v1.42.0 (12 Jun 2026) split into open-telemetry/semantic-conventions-genai; MCP conventions merged; gen_ai.system → gen_ai.provider.name (<https://dev.to/azena-ai/opentelemetrys-genai-semantic-conventions-are-not-stable-yet-heres-what-actually-shipped-in-2026-3mke>).
- MCP donated to the Linux Foundation Agentic AI Foundation (AAIF), formed 9 Dec 2025 with MCP, goose, AGENTS.md; platinum members AWS, Anthropic, Block, Bloomberg, Cloudflare, Google, Microsoft, OpenAI (<https://www.linuxfoundation.org/press/linux-foundation-announces-the-formation-of-the-agentic-ai-foundation>). Spec 2026-07-28: stateless transport (no Mcp-Session-Id), RFC 9207 issuer validation, Client ID Metadata Documents, Tasks extension (<https://blog.modelcontextprotocol.io/posts/2026-07-28/>).
- A2A v1.0 stable (Mar/Apr 2026), signed Agent Cards; 150+ orgs; joined AAIF 17 Aug 2026; authorization out of scope (<https://www.linuxfoundation.org/press/a2a-protocol-surpasses-150-organizations-lands-in-major-cloud-platforms-and-sees-enterprise-production-use-in-first-year>).
- AGNTCY (Cisco) donated to LF July 2025 (https://www.theregister.com/2025/07/30/agtncy_if_donation/). W3C AI Agent Protocol CG (May 2025), no standards-track output (<https://github.com/w3c-cg/ai-agent-protocol>).
- IETF AIPREF: draft-ietf-aipref-vocab-07 (19 Aug 2026) and draft-ietf-aipref-attach (Content-Usage header; robots.txt content-usage) (<https://datatracker.ietf.org/doc/draft-ietf-aipref-vocab/>). llms.txt: no body, no confirmed consumption.

7. Supply chain & BOMs

CycloneDX 1.7 (21 Oct 2025; ECMA-424; ML-BOM) (<https://cyclonedx.org/specification/overview/>); SPDX 3.0.1 AI and Dataset profiles (<https://spdx.github.io/spdx-spec/v3.0.1/model/AI/AI/>); ISO/IEC DIS 5962 vote closed 9 Jun 2026 (<https://www.iso.org/standard/93810.html>); Hugging Face model cards; Anthropic system cards (<https://www.anthropic.com/system-cards>). "AI nutrition labels" — no standard found. BOMs describe the artefact, not the transaction.

8. Incident registries

OECD AI Incidents Monitor and the Feb 2025 common reporting framework (https://www.oecd.org/en/publications/towards-a-common-reporting-framework-for-ai-incidents_f326d4ac-en.html); AI Incident Database; AIAAIC; MIT AI Incident Tracker June 2026 update (<https://airisk.mit.edu/bl og/ai-incident-tracker-june-2026-update>). None accepts a machine-verifiable session reference.

9. Named groups

- "UP Path" / "UP-Path" / "UPPath" / "Unified Path" / "Universal Protocol": nothing credible exists as an AI-governance body. Hits resolve to UiPath (PATH; founding contributor to AIUC-1, 19 Nov 2025: <https://ir.uipath.com/news/detail/418/uipath-becomes-founding-contributor-to-ai-uc-1-joining-aiuc-in-promoting-security-standards-for-enterprise-ai-adoption>), Google's Universal Commerce Protocol, UTCP, and an arXiv paper. Read as UiPath → AIUC-1.
- AIUC-1: insurance-backed agent standard (Orrick, Stanford, CSA, MIT, MITRE); UiPath certified (<https://www.uipath.com/newsroom/uipath-achieves-aiuc-1-certification>).
- Frontier Model Forum briefs: incident sharing (12 May 2026), agent security practices (3 Jun 2026) (<https://www.frontiermodelforum.org/publications/>). Partnership on AI Six AI Governance Priorities (11 Feb 2026) (<https://partnershiponai.org/resource/six-ai-governance-priorities/>). MLCommons AILuminate v1.1. ETSI EN 304 223 (May 2026) (<https://www.etsi.org/enjoy-magazine/articles/ai-cybersecurity-standard-etsi-en-304-223/>). IEEE 7001-2021; CertifAIEd (2022). ITU AI for Good Standards Exchange. Trustmarks: ISO 42001 certification bodies; Nemko AI Trust Mark. AI Alliance / DPGA 2026 activity unverified.

10. Gap analysis — what nobody covers for a stranger verifying one AI transaction end to end

1. No transaction identifier standard (only China's reference number; MCP removed session ids; OTel unsigned/unstable).
2. Identity split three ways (human / workload / agent-model) with no binding at call time.
3. Policy decisions asserted, not attested (only OVERT, single vendor, no IAPs; prEN 18229-1 at Enquiry).
4. Transparency logs (RFC 9943/9942) have no AI statement profile; OVERT does not reference SCITT; Rekord v2 dropped attestation storage.
5. Content provenance asset-bound, not session-bound; text/voice/code carry nothing.

6. Audit rights stop at the organisation; no "verify offline with a public key" norm.
7. Incident linkage manual — no registry takes a receipt hash.
8. Interface coverage uneven — voice, IDE, on-device, browser extension, A2A.

The protocol therefore needs: a session/transaction id and receipt schema profiled as a SCITT Signed Statement (COSE) with an RFC 9942 receipt; a binding claim set (human VC/OIDC subject, agent SPIFFE/DID, model hash/BOM ref, policy-decision hash, C2PA manifest hash); a registration policy per interface; and an incident record that cites the receipt.

Research memo 2 — AIUC-1, Glacis, agentic-commerce receipts, stakeholder needs, prior art, privacy (13 September 2026)

Companion to memo 1. Items that could not be confirmed are marked "unverified". Researched with web search on 13 September 2026 by Claude for Bob Rapp.

A. AIUC-1

- Publisher: Artificial Intelligence Underwriting Company (San Francisco; founder Rune Kvist, ex-Anthropic; \$15M seed led by Nat Friedman) (<https://agentmarketcap.ai/blog/2026/04/15/ai-agent-error-insurance-lloyds-aig-beazley-hallucination-liability>). Developed with Orrick, MITRE, CSA, Stanford, MIT (<https://ir.uiopath.com/news/detail/418/uiopath-becomes-founding-contributor-to-aiuc-1-joining-aiuc-in-promoting-security-standards-for-enterprise-ai-adoption>).
- Versions: launch 22 July 2025; quarterly releases 1 Oct 2025, 15 Jan 2026 (voice-agent controls), 15 Apr 2026, 15 Jul 2026 (current; next 15 Oct 2026); July 2026 added coding-agent requirements A008 (secrets leakage) and B010 (secure generated code) (<https://www.aiuc-1.com/changelog>).
- Domains: six — Data & Privacy, Security, Safety, Reliability, Accountability, Society (<https://www.aiuc-1.com/>; <https://www.tevora.com/resource/what-is-aiuc-1-a-guide-to-the-newest-ai-compliance-framework/>; <https://mindgard.ai/blog/aiuc-1-explained>). 51 requirements / 130 controls (65 mandatory) per one secondary source — unverified (<https://vettedaiagents.com/aiuc-1/>).
- Audit model: accredited third-party audit (Schellman first) plus adversarial testing across thousands of scenarios, re-run at least quarterly; certificates valid 12 months but lapse without quarterly re-testing; 5–10 weeks to certify (<https://www.uiopath.com/newsroom/uiopath-achieves-aiuc-1-certification>).
- Insurance: framework + audits + liability cover priced off audit results; AIUC as MGA with carriers such as Beazley; limits unpublished.
- Certified: Intercom Fin (Dec 2025), UiPath (9 Mar 2026), and per aiuc-1.com KPMG, Cursor, Harvey, ElevenLabs.
- Governance: 120+ member consortium (Stanford, Microsoft, Google Cloud, Meta, Anthropic, Databricks, IBM, Salesforce, Fidelity, Visa, 100+ Fortune-500 CISOs); 200+ peer-review comments per cycle; technical contributors MITRE, Cisco, ElevenLabs, UiPath, OWASP; no published charter, voting rule or independent steering body — AIUC is sole editor (unverified beyond the site).
- Fees: unpublished; "aimed at large-scale businesses".
- Criticism: vertical integration / issuer-pays — AIUC writes the standard, accredits auditors, underwrites (<https://mindgard.ai/blog/aiuc-1-explained>). No academic or civil-society critique found.
- Relation: ISO 42001 certifies the organisation's management system; AIUC-1 certifies a specific deployed agent by behaviour testing; both crosswalk to ISO 42001 / NIST / EU AI Act; neither AIUC-1 nor OVERT references the other (unverified). AIUC-1 = periodic certificate; OVERT AAL-3/4 = per-decision signed receipt. Complementary layers.
- "UP Path" = UiPath: founding contributor (Nov 2025) and first enterprise-automation platform certified (Mar 2026).

B. Glacis

- Company: Seattle; Joe Braidwood CEO, Dr Jennifer Shannon CMO, Rohit Tatachar co-founder/CTO (Apr 2026); \$575k pre-seed (Safe AI Fund, Mighty Capital, Sourdough, AI2 Incubator), Cloudflare Launchpad, Plug and Play Seattle; two healthcare pilots; seed targeted later 2026, no close announced (unverified); pricing \$49/mo starter, \$499/mo pro (<https://www.geekwire.com/2026/seattle-startup-glacis-brings-longtime-microsoft-leader-aboard-to-target-ais-biggest-blind-spot/>). "Glacis Labs" (\$6.8M, July 2026) is an unrelated crypto company.
- Naming: GeekWire says Arbiter + Witness Network; current docs say governance proxy, Notary, Dashboard; the verifier page mentions "two internal arbiters: a network proxy and an endpoint guard (Pulse)" (<https://docs.glacis.io/runtime/>; <https://verify.glacis.io/>). No public Witness Network docs (unverified).
- Receipt format glacis.receipt.v1: Ed25519 over RFC 8785 JCS canonical JSON; SHA-256 of input/output; attestation_hash; key fingerprints; "every field is a hash, a counter, a key, or a label"; line-ranges not text; RFC 6962-shaped Merkle log with inclusion proof, signed checkpoint, consistency proof; `pip install glacis && python -m glacis verify receipt.json`, offline, cross-runtime Rust/TS/Python; offline-only receipts labelled UNVERIFIED for third parties (AAL-3 max); SDK v0.8.0 (24 Mar 2026), Apache-2.0, fields attestation_id, timestamp, service_id, operation type, input/output hashes, control-plane results, signature (<https://docs.glacis.io/verify/>; <https://docs.glacis.io/overt/conformance-ladder/>; <https://github.com/Glacis-io/glacis-python>).
- Assurance: AAL-1 self-attestation → AAL-2 live enforcement → AAL-3 signed, chained, operator-hosted notary → AAL-4 notary outside the operator's trust boundary plus a qualified, structurally independent assessor; Glacis's own bundle is AAL-3 and "must not be represented as AAL-4".
- Qualified assessor / IAP registry: defined in OVERT 1.1 Part V §22; no public registry or named assessor (unverified).
- Partners: nVoq, PACT AI (founding member, 26 Aug 2026), DiMe, CHAI, ScaleHealth, EisnerAmper, Cloudflare (<https://www.glacis.io/>). Nature of CHAI/DiMe relationships unverified.
- Criticism: none public. Structural: the OVERT steward sells the runtime and would qualify assessors.

- Competing signed per-inference records: Attested Intelligence "AGA" (Ed25519/ML-DSA-65 hybrid, hash-linked receipts, offline bundles, TS/Go/Python, live verifier) (<https://attestedintelligence.com/>); Pangea Secure Audit Log (tamper-evident Merkle log, not a caller-held receipt) (<https://pangea.cloud/docs/audit/overview/about>). Credo AI, Holistic AI, Vera, Arthur, Fiddler, WitnessAI, Lakera, Guardrails AI, Cranium, Vijil, Zenity: no public per-inference signed receipts found (unverified individually).

C. Agentic commerce protocols

PROTOCOL	STATUS / DATE	WHAT IS SIGNED	HUMAN INTENT BINDING	VERIFIABLE LATER	SOURCE
Google AP2	Open spec 16 Sep 2025; 60+ partners; A2A x402 extension	Intent, Cart, Payment Mandates as Verifiable Credentials	Human-present: user signs Cart Mandate; human-not-present: pre-signed Intent Mandate with limits	Non-repudiable intent → cart → payment chain	https://cloud.google.com/blog/products/ai-machine-learning/announcing-agents-to-payments-ap2-protocol
Visa Trusted Agent Protocol	14 Oct 2025 with Cloudflare; Microsoft, Shopify, Stripe, Adyen, Worldpay; open GitHub	RFC 9421 HTTP Message Signatures (timestamp, session id, keyid, alg) bound to domain and operation	Weak — agent-asserted intent; no user-signed mandate	Agent legitimacy, replay prevention	https://corporate.visa.com/en/sites/visa-perspectives/newsroom/visa-unveils-trusted-agent-protocol-for-ai-commerce.html ; https://github.com/visa/trusted-agent-protocol
Mastercard Agent Pay / Verifiable Intent	Agent Pay live; Verifiable Intent open standard announced 5 Mar 2026 with Google, Fiserv, IBM, Checkout.com	Tamper-resistant record linking consumer identity, instructions, outcome; selective disclosure	Explicit consent before action; agent registration	Authorization validity, adherence, outcome	https://www.pymnts.com/mastercard/2026/mastercard-unveils-open-standard-to-verify-ai-agent-transactions/
OpenAI/Stripe ACP Delegated Payment	API 2025-09-29; live in ChatGPT Instant Checkout	Single-use vault token with allowance {max_amount, expires_at, merchant_id, checkout_session_id}; Signature, Timestamp, Idempotency-Key	Consent only via checkout_session_id — no user-signed artifact	Authenticity, freshness, idempotency, allowance	https://developers.openai.com/commerce/specs/payment
Shopify/Google UCP	11 Jan 2026; Etsy, Target, Walmart, Wayfair	Capabilities only; no signed receipt	Not addressed	Not addressed	https://shopify.engineering/UCP
PayPal Agentic Commerce Services	28 Oct 2025	Not published (unverified)	—	—	https://newsroom.paypal-corp.com/2025-10-28-PayPal-Launches-Agentic-Commerce-Services-to-Power-AI-Driven-Shopping
Cloudflare Web Bot Auth	In Verified Bots since 1 Jul 2025; IETF WG; draft-meunier-web-bot-auth-architecture-05 (2 Mar 2026)	RFC 9421 signature over @authority/@target-uri; key directory at .well-known	Explicitly must NOT bind a human — keys represent a role/company/automation	Bot/operator identity only	https://blog.cloudflare.com/verified-bots-with-cryptography/ ; https://datatracker.ietf.org/doc/html/draft-meunier-web-bot-auth-architecture

Only AP2 (and Mastercard Verifiable Intent, once specified) produces a user-signed mandate; TAP / Web Bot Auth / ACP prove agent or session identity, not consent. None records what the model did between intent and cart.

D. Stakeholder needs

- Buyers/deployers. NYC Local Law 144: the NY State Comptroller (2 Dec 2025) found DCWP received only 2 complaints, took no enforcement action, and missed at least 17 potential violations among 32 employers checked (<https://www.osc.ny.gov/state-agencies/audits/2025/12/02/enforcement-local-law-144-automated-employment-decision-tools>). EU MCC-AI updated 5 Mar 2025: High-Risk and Light templates mirroring Chapter III (<https://public-buyers-community.ec.europa.eu/communities/procurement-ai/resources/updated-eu-ai-model-contractual-clauses>). AI Act Art. 26(6): deployers keep logs under their control ≥ 6 months, from 2 Dec 2027 for Annex III (<https://www.legalit-hm.com/en/blog/eu-ai-act-log-retention-record-keeping-6-months>). Need: per-call evidence that certified controls ran on their traffic.

2. End users. Art. 50 (from 2 Aug 2026) and Art. 86 right to a "clear and meaningful explanation of the role of the AI system and the main elements of the decision" (<https://artificialintelligenceact.eu/article/86/>). Colorado SB 26-189 (effective 1 Jan 2027): disclosure, post-adverse-decision explanation, correction, human review, 3-year records, AG enforcement (<https://www.consumerfinancemonitor.com/2026/05/12/colorado-rewrites-its-landmark-ai-law-unpacking-sb-26-189-and-what-it-means-for-businesses/>). Korea AI Basic Act (22 Jan 2026): advance notice, labelling, meaningful explanation. "Disclosure by Design" (Mar 2026): models' self-disclosure of AI identity collapses under role-play — an out-of-band verifiable receipt is needed (<https://arxiv.org/pdf/2603.16874>). No shipping "AI receipt for the user" beyond Glacis's verify page (unverified).
3. Regulators. FTC 6(b) orders 11 Sep 2025 to seven companion-chatbot makers (persona design, engagement features, monetisation, age-gating, testing/monitoring, sensitive-content handling, complaints); 44 state AGs letter 25 Aug 2025 (<https://www.dlapiper.com/en-us/insights/publications/2025/09/ftc-ai-chatbots>). Operation AI Comply orders centre on substantiation records (<https://www.aipolicydesk.com/blog/ftc-ai-enforcement-actions-2026>). Italy: Garante €15M OpenAI fine annulled by the Court of Rome 19 Mar 2026; DeepSeek blocked since Jan 2025. No regulator specifies a log format (unverified). Art. 78: authorities request only what is strictly necessary; protect source code and trade secrets (<https://artificialintelligenceact.eu/article/78/>).
4. Civil society. Ada Lovelace *Code & Conduct* (Jun 2024): data access is the greatest obstacle to audits; calls for mandated auditor access, auditor standards, public registers, challenge mechanisms (<https://www.adalovelaceinstitute.org/report/code-conduct-ai/>). EU Art. 71 database not yet publicly operational; Annex III registration due 2 Dec 2027; non-public section for law enforcement/migration (<https://artificialintelligenceact.eu/article/71/>). UK ATRS mandatory for central-government tools that significantly influence a decision or interact with the public (<https://gov.uk/government/publications/algorithmic-transparency-recording-standard-mandatory-scope-and-exemptions-policy/algorithmic-transparency-recording-standard-atrs-mandatory-scope-and-exemptions-policy>). AI Now, AJL, EFF, Access Now, AlgorithmWatch, Mozilla not individually fetched (unverified).
5. Sellers/vendors. Resistance grounded in Art. 78 confidentiality and Art. 86's "main elements" limit. Incentives: AIUC cover priced off audits; Armilla (Lloyd's coverholder, Chaucer, up to \$25M, Apr 2025) covers hallucination, drift, data leakage; Munich Re aiSure (up to \$15M per vendor) (<https://www.armilla.ai/>). Insurers publish no log format (unverified).

E. Prior art — one receipt per interaction

PROPOSAL	TYPE	STATUS
Glacis/OVERT signed receipts	Industry	Shipping (AAL-3); AAL-4 not yet achievable
Attested Intelligence AGA	Industry spec + SDKs	Shipping, small
AP2 mandates	Industry	Spec + reference impl; production use unverified
zkML proof of inference — Lagrange DeepProve-1 proved full GPT-2 inference (18 Aug 2025); EZKL; zkLLM	Research → early product	Not viable per request at frontier scale (https://lagrange.dev/blog/deepprove-1 ; https://arxiv.org/pdf/2404.16109)
TEE attestation — Apple PCC expanded to Google Cloud (8 Jun 2026); Google Confidential Space H100 GA; Intel Trust Authority (23 Jun 2026); "Attestable Audits" (Jun 2025)	Shipping (infrastructure)	Attests environment/binary, not per-response content (https://security.apple.com/blog/expanding-pcc/ ; https://cloud.google.com/blog/products/identity-security/verifiable-trust-in-the-ai-era-whats-new-in-confidential-computing ; https://arxiv.org/abs/2506.23706)
OpenAI Deployment Safety Hub; Anthropic Transparency Hub	Industry	Model-level only; no per-session artefacts (https://deploymentsafety.openai.com/ ; https://www.anthropic.com/transparency)
"Google AI transparency receipts"	—	Not found; likely conflation with SynthID

F. Privacy constraints

- Minimisation and storage limitation: Art. 12 logging and Art. 19/26(6) six-month floor apply "unless provided otherwise" by data-protection law; receipts content-free by default.
- Content-free hashing: Glacis (hashes + line ranges), AGA (hash-linked). Unsalted hashes of short prompts are dictionary-attackable — use salted/HMAC commitments (design inference; unverified against any standard).
- Tension with Art. 86 / GDPR Art. 22: a hash cannot explain; the receipt must reference an explanation record disclosable on demand.
- Selective disclosure: SD-JWT is RFC 9901 (Nov 2025); SD-JWT VC at draft-19; BBS+ still a CFRG draft (<https://www.rfc-editor.org/info/rfc9901>). Mastercard Verifiable Intent already uses selective disclosure.
- Identity binding: Web Bot Auth forbids human-bound keys; separate operator identity (Web Bot Auth), agent identity (TAP), human mandate (AP2 VC).

G. Design constraints the protocol must satisfy

STAKEHOLDER	VERIFIABLE QUESTION	EXISTING ANSWER
Buyer/deployer	Which model/version and system-prompt hash served this call?	OTel GenAI attrs (unsigned); Glacis receipt (signed)
	Did the vendor's certified controls execute on this call?	OVERT ControlAction only; AIUC-1 is periodic

STAKEHOLDER	VERIFIABLE QUESTION	EXISTING ANSWER
	Can I retain evidence ≥ 6 months without content?	Hash-only receipts — no open standard
	Was a human in the loop when policy required?	None per call
End user	Was I talking to an AI, and which operator?	Art. 50 / Korea notice — non-verifiable text
	What did I authorise and did the agent stay within it?	AP2 mandates (commerce only)
	Can I get the Art. 86 / SB 26-189 explanation from this exact interaction?	None — needs receipt → explanation-record pointer
	Can I prove deletion of my session?	None
Regulator	Is the substantiation for a claim traceable to production runs?	None
	Was the log altered after the incident?	RFC 6962 logs (Glacis); SCITT
	Can I inspect without trade secrets (Art. 78)?	Hash-only + SD-JWT partially
Civil society	Is the system in a public register, referenced by the receipt?	Art. 71 DB (not live), ATRS — no linkage
	Can an independent auditor verify a sample without vendor cooperation?	OVERT AAL-4 (no assessors yet)
	Is there a complaint channel keyed to the receipt id?	None (LL144 shows channels fail without artefacts)
Vendor	Can I prove controls ran without exposing prompts/weights?	Content-free receipts; TEE attestation of binary
	Does the receipt reduce premium/liability?	Insurers price on audits, not yet receipts (unverified)
	Are operator/agent/human identities separated?	Web Bot Auth / TAP / AP2 — three unlinked layers

Derived: (1) content-free, salted commitments with a disclosure pointer; (2) Ed25519/JCS + RFC 6962 inclusion proofs; (3) three separable identity layers; (4) a mandate slot compatible with AP2 VCs; (5) a registry-reference field; (6) selective disclosure via SD-JWT; (7) a certificate-to-receipt link; (8) notary and assessor outside the operator's trust boundary.